

Data leak worksheet

Incident summary:

A customer success representative was given access to a folder containing internal company documents, including customer analytics and marketing materials for a new product. The manager forgot to remove the representative's access after it was no longer needed.

Later, during a sales call, the representative meant to share a link to the marketing materials with an external business partner. Instead, they accidentally shared the entire folder. The business partner then posted the folder link on social media, exposing confidential company documents.

Control	Least privilege
Issue(s)	<i>The data leak happened because the manager gave the employee access to confidential files and forgot to remove that access when it was no longer needed. The employee then accidentally shared the entire folder instead of a single file, exposing sensitive company information to an external business partner.</i>
Review	<i>NIST SP 800-53 AC-6 focuses on the principle of least privilege. It states that users should only have the minimum access needed to perform their job. The control also recommends restricting access by role, automatically removing access when it is no longer needed, keeping activity logs, and regularly reviewing user permissions.</i>
Recommendation(s)	<i>Automatically revoke access to information after a set period of time. Regularly audit user privileges to ensure employees only have the access they need for their job roles.</i>
Justification	<i>Automatically removing access would prevent employees from keeping permissions longer than necessary. Regular privilege audits would help</i>

	<i>identify and remove unnecessary access before it leads to another accidental data leak, improving the protection of confidential company information.</i>
--	--

Security plan snapshot

The NIST Cybersecurity Framework (CSF) uses a structured approach to organize security information. It begins with a broad security function and becomes more specific through categories, subcategories, and individual security controls.

Function	Category	Subcategory	Reference(s)
Protect	PR.DS: <i>Data security</i>	PR.DS-5: <i>Protections against data leaks.</i>	NIST SP 800-53: AC-6

The company uses NIST SP 800-53 as a guideline for protecting sensitive information and improving privacy controls. The AC-6 Least Privilege control helps prevent data leaks by ensuring users only receive the access required to complete their job responsibilities.

NIST SP 800-53: AC-6

NIST SP 800-53 provides organizations with security and privacy guidelines that can be customized to meet their needs. Each control includes a description of the security requirement, guidance for implementation, and control enhancements that improve security effectiveness.

AC-6	Least Privilege
-------------	------------------------

	Control: Only the minimum access and authorization required to complete a task or function should be provided to users.
	Discussion: Organizations should manage user accounts, roles, and permissions to enforce least privilege. The goal is to prevent users from having higher access levels than necessary to complete business tasks and reduce the risk of unauthorized data exposure.
	Control enhancements: • Restrict access to sensitive resources based on user role. • Automatically revoke access to information after a specific period of time. • Maintain activity logs for user accounts and access. • Regularly audit user privileges.

Note: Within the NIST SP 800-53 Access Control category, Least Privilege is identified as control **AC-6**.